

The market for zero-day exploits is commercial activity related to the trafficking of software exploits.

Software vulnerabilities and "exploits" are used to get remote access to both stored information and information generated in real time. When most people use the same software, as is the case in most of countries today given the monopolistic nature of internet content and service providers, one specific vulnerability can be used against thousands if not millions of people. In this context, criminals have become interested in such vulnerabilities. A 2014 report from McAfee's Center for Strategic and International Studies estimates that the cost of cybercrime and cyberespionage is somewhere around \$160 billion per year. Worldwide, countries have appointed public institutions to deal with this issue, but they will likely conflict with the interest of their own government to access people's information in order to prevent crime. As a result, both national security agencies and criminals hide certain software vulnerabilities from both users and the original developer. This type of vulnerability is known as a zero-day exploit.

Much has been said in academia and regular media about the regulation of zero-day exploits in the market. However, it is very difficult to reach a consensus because most definitions for zero-day exploits are rather vague or not applicable, as one can only define the use of certain software as malware after it has been used. In addition, there is a conflict of interest within the operations of the state that could prevent a regulation that can make mandatory the disclosure of zero-days. Governments face a trade-off between protecting their citizens' privacy through the reporting of vulnerabilities to private companies on one hand and undermining the communication technologies used by their targets—who also threaten the security of the public—on the other. The protection of national security through exploitation of software vulnerabilities unknown to both companies and the public is an ultimate resource for security agencies but also compromises the safety of every single user because any third party, including criminal organizations, could be making use of the same resource. Hence,

only users and private firms have incentives to minimize the risks associated with zero-day exploits; the former to avoid an invasion of privacy and the latter to reduce the costs of data breaches. These include legal processes, costs related to the development of solutions to fix or "patch" the original vulnerability in the software and costs associated with the loss of confidence of clients in the product.

Description

Ablon, Libicki and Golay have explained to a great extent the inner workings of the zero-day market. The main findings can be separated into five components: Commodity, Currency, Marketplace, Supply and Demand. These components and their relationship with pricing will be described. The definition given to the demand component will also be challenged because it is paramount to understand the nature of the markets (i.e. white, gray and black) and its regulation or lack thereof.

Commodity

Exploits are digital products, which means that they are information goods with near-zero marginal production costs. However, they are atypical information goods. Unlike e-books or digital videos, they do not lose their value because they are easy to replicate but due to the fact that once they are exposed, the original developer will "patch" the vulnerability, decreasing the value of the commodity.

The value will not go to zero for two reasons: (1) the distribution of the patch is asymmetric and (2) developers could use the original bug to create a variant at a decreased cost. They are also atypical because they are time-sensitive commodities. Companies are updating their software on a regular basis and a patch is only useful during the lapse between versions; sometimes a vulnerability can be corrected without any external report. Third, even in

confidential transactions, the use of the exploit itself can create a dysfunction on the user-end, exposing the vulnerability and leading to its loss of value. In this sense, exploits are non-excludable but they can or can not be non-rivalrous, as the more users use a zero day exploit after a certain point, the more visible its impact will be to the company in question. This could result in the company being more likely to patch the exploit, resulting in a limited period of time where the exploit is available for all users.

Currency

In most cases, transactions are typically designed to protect the identity of at least one of the parties involved in the exchange. While this is dependent on the type of market—white markets can use traceable money—most purchases are made with stolen digital funds (credit cards) and cryptocurrencies. While the latter has been the dominant trend in the last few years, prices in the gray market are set in dollars, as shown by the leaks of Hacking Team's email archive.

Marketplace

Classically, black markets—like illegal weapons or narcotics—require a huge network of trusted parties to perform the transactions of deal-making, document forgery, financial transfers and illicit transport, among others. As it is very difficult to enforce any legal agreement within these networks, many criminal organizations recruit members close to home. This proximity element increases the cost of transaction as more intermediaries are required for transnational transactions, decreasing the overall profit of the original seller.

Zero-days, on the other hand, are virtual products and can be easily sold without intermediaries over the internet as available technologies are strong enough to provide anonymity at a very low cost. Even if there is a need for intermediaries, "unwitting data mules" can be used to avoid any evidence of wrongdoing. This is why the black market is so lucrative

compared to gray markets. Gray markets, which involve transactions with public institutions in charge of national security, usually require the use of third parties to hide the traces of their transactions. The Hacking Team archive, for example, contains alleged contracts with the Ecuadorian National Secretariat of Intelligence where they used two intermediaries: Robotec and Theola. In the same archive, it is said that third-party companies Cicom and Robotec negotiated the contracts on behalf of the FBI and DEA respectively. It is less likely that white markets face the same problem as it is not in their interest to hide the transaction, it is quite the opposite because companies actively promote the use of their new patches.

Supply

The supply chain is complex and involves multiple actors organized by hierarchies, where administrators sit at the top, followed by the technical experts. Next are intermediaries, brokers and vendors which can or can not be sophisticated, finally followed by witting mules. Within this chain of command, one can find multiple products. While zero-day exploits can be "found" or developed by subject matter experts only, other exploits can be easily commercialized by almost any person willing to enter the black market. There are two reasons for this. First, some devices use outdated or deprecated software and can be easily targeted by exploits that otherwise would be completely useless. Second, these "half-day exploits" can be used through graphical interfaces and learned through freely available tutorials, which means that very little expertise is required to enter the market as a seller.

The coexistence of zero-day and half-day markets influences the resilience of the black market, as developers keep moving towards the more sophisticated end. While take-downs on high organized crime has increased, the suppliers are easily replaced with people in lower levels of the pyramid. It can take less than a day to find a new provider after a take-down operation that can easily last months.

Getting to the top, however, requires personal connections and a good reputation, in this the

digital black market is no different from the physical one. Half-day exploits are usually traded in more easily accessible places but zero-days often require "double-blind" auctions and the use of multiple layers of encryption to evade law enforcement. This can not be done in forums or boards, hence these transactions occur in extremely vetted spaces.

Demand

Afidler differentiates between white, gray and black markets following the market-sizing methodology from Harvard Business School as a guide. Here they differentiate between white markets, gray markets and black markets.

White markets are those where the original developers reward security researchers for reporting vulnerabilities. On average, prices reported until 2014 were less than ten thousands of dollars but special offers up to \$100,000 were made to certain vulnerabilities based on the type, criticality, and nature of the affected software. Fourteen percent of all Microsoft, Apple and Adobe vulnerabilities in the past ten years came through white market programs.

Criminals buy in the black market; however, governments can be occasional buyers if their offer can not be satisfied in the gray market or if they find impediments to acquire zero-days due to international regulations. Hacking Team states in their website that they "do not sell products to governments or to countries blacklisted by the U.S., EU, UN, NATO or ASEAN", although they have been found infringing their own policy. Prices are usually 10–100 times higher in this market when compared to the white market and this changes depending on the location of the buyer; The United States being the place where the best prices are offered. Potential sellers which are not allowed to sell in specific territories, like Cuba and North Korea in the case of the U.S., are likely to operate in the black market as well.

Gray markets buyers include clients from the private sector, governments and brokers who resell vulnerabilities. The information regarding these markets is only available through requests of confidential information from governments, where the price is usually redacted

for safety purposes, and information leaked from both national security agencies and private companies (i.e. FinFisher and Hacking Team).

Tsyrklevich reported on the transactions made by Hacking Team. To date, this represents the best evidence available on the inner workings of the gray market. However, it is likely to be the case that some of these procedures are applied in both white and black markets as well:

Buyers follow standard technology purchasing practices around testing, delivery, and acceptance. Warranty and requirements negotiations become necessary in purchasing a product intrinsically predicated on the existence of information asymmetry between the buyer and the seller. Requirements—like targeted software configurations—are important to negotiate ahead of time because adding support for new targets might be impossible or not worth the effort. Likewise warranty provisions for buyers are common so they can minimize risk by parceling out payments over a set time frame and terminating payments early if the vulnerability is patched before that time frame is complete. Payments are typically made after a 0day exploit has been delivered and tested against requirements, necessitating sellers to trust buyers to act in good faith. Similarly, buyers purchasing exploits must trust the sellers not to expose the vulnerability or share it with others if it's sold on an exclusive basis.

Controversies

Typically the parties opposed to gray markets are the retailers of the item in the market as it damages its profits and reputation. As a result, they usually pressure the original manufacturer to adjust the official channels of distribution. The state also plays an important role enforcing penalties in the case of law infringement. However, the zero-day exploit market is atypical and the way it operates is closer to the workings of the black market. Brokers and bounty programs, which could be seen as retailers of zero-days, have no control whatsoever on the original producers of the "bad" as they are independently discovered by different, and

often anonymous, actors. It is not in their interest to change the channel of distribution as they can profit from both the white and gray markets, having much less risk in the former. States, which usually complement the labour of the original manufacturers to restrict gray markets, play a different role in the zero-day market as they are regular purchasers of exploits. Given the secretive nature of information security, it is not in their interest to disclose information on software vulnerabilities as their interest is, in this case, aligned with that of the criminals who seek to infiltrate devices and acquire information of specific targets. It can be argued that the presence of intelligence agencies as consumers of this "bad" could increase the price of zero-days even further as legitimate markets provide bargaining power to black-market sellers.

Finally, private companies are unwilling to raise the prices of their rewards to those levels reached in the gray and black markets arguing that they are not sustainable for defensive markets. Previous studies have shown that reward programs are more cost-effective for private firms as compared to hiring in-house security researchers, but if the prize of rewards keeps increasing that might not be the case anymore.

In 2015, Zerodium, a new start-up focused on the acquisition of "high-risk vulnerabilities", announced their new bounty program. They published the formats required for vulnerability submissions, their criteria to determine prices—the popularity and complexity of the affected software, and the quality of the submitted exploit—and the prices themselves. This represents a mixture of the transparency offered by traditional vulnerability reward program and the high rewards offered in the gray and black markets. Software developer companies perceived this new approach as a threat, primarily due to the fact that very high bounties could cause developer and tester employees to leave their day jobs. Its effects on the market, however, are yet to be defined.

The NSA was criticized for buying up and stockpiling zero-day vulnerabilities, keeping them secret and developing mainly offensive capabilities instead of helping patch vulnerabilities.

See also

Bug bounty program

Cybercrime

Cybercrime countermeasures

Cyber-arms industry

Duqu

Mass surveillance industry

Stuxnet

Proactive cyber defense

== References ==